# 信息安全测评与风险评估

7.1.2 云安全配置核查

授课教师：张玉



# 目录

CONTENTS


01 案例导入——“一个配置错误，百万数据泄露”

02 学习目标

03 复习导入——回顾云平台架构与责任共担

04 云计算安全扩展要求——在等保标准中的定位

# 案例导入——“一个配置错误，百万数据泄露”

思政7.1.2：Capital One：一次



**引入问题 云平台配置好了，但——你真的“配置安全”了吗？**

## 问题讨论

数据泄露事件，是云服务商的责任还是客户的责任？

**云平台配置错误是云安全风险的主要来源之一。等保测评中，需要对云平台的安全配置进行逐项核查。**

# 学习目标

01 **掌握**云计算安全扩展要求的核心测评指标

02 **理解**云计算平台安全配置核查的方法与流程

03 **能够**对模拟云平台进行安全配置核查

04 **能够**规范填写《云计算安全测评记录表》

05 **具备**云平台安全配置风险识别能力

# 复习导入——回顾云平台架构与责任共担

## 快速问答

| 问题 | 学生回答 |
| --- | --- |
| 云计算的三种服务模式是什么？ | |
| IaaS模式下，谁负责操作系统的安全？ | |
| PaaS模式下，谁负责数据安全？ | |
| 基础设施位于中国境内是谁的责任？ | |

| 问题 | 学生回答（参考答案） | 教师点评 |
| --- | --- | --- |
| 云计算的三种服务模式是什么? | IaaS（基础设施即服务）、PaaS（平台即服务）、SaaS（软件即服务）。口诀：基、平、软——从底层到上层，云服务商管得越来越多，租户管得越来越少。 | 基础概念题，三种模式必须熟记。注意区分：IaaS 租的是 "虚拟机"，PaaS 租的是 "开发平台"，SaaS 租的是 "现成软件"。 |
| IaaS 模式下，谁负责操作系统的安全? | 租户（用户）负责。云服务商管：物理机房、网络设备、服务器硬件、虚拟化层；租户管：操作系统补丁、中间件、应用程序、数据。 | 这是责任共担模型的核心考点。IaaS 模式下，云服务商把 "裸机 + 虚拟化" 给你，操作系统以上全是自己管 —— 装系统、打补丁、配安全策略都靠自己。 |
| PaaS 模式下，谁负责数据安全? | 租户（用户）负责数据安全。云服务商管：操作系统、中间件、运行环境、数据库平台本身；租户管：数据内容、数据访问权限、应用逻辑、API 调用安全。 | 易错点！PaaS 不是 "什么都不用管"—— 数据永远是租户自己的责任。平台安全云服务商兜底，但数据有没有泄露、有没有被越权访问，全在租户。 |
| 基础设施位于中国境内是谁的责任? | 云服务商的责任。根据等保 2.0 云计算扩展要求，云服务商应确保云计算基础设施位于中国境内。 | 等保 2.0 云扩要求中的硬性条款。注意区分：物理境内存续是云服务商的事，但租户业务数据的合规存储和跨境传输，租户也要担责。 |



敲黑板

云安全责任共担模型中，**数据安全永远是客户的责任**。云安全配置核查，就是帮助客户检查“自己负责的那部分”是否配置到位。

# 云计算安全扩展要求——在等保标准中的定位

- **GB/T 22239-2019 第三级/第四级 → 8.2/9.2 云计算安全扩展要求**

**七个安全类：**

| 序号 | 安全类 | 核心关注点 | 测评方法 |
| --- | --- | --- | --- |
| 1 | 安全物理环境 | 基础设施位置 | 文档审查 |
| 2 | 安全通信网络 | 网络架构（隔离、冗余、自主配置） | 核查+访谈 |
| 3 | 安全区域边界 | 访问控制、入侵防范、安全审计 | 核查+测试 |
| 4 | 安全计算环境 | 身份鉴别、访问控制、镜像快照、数据保护、备份恢复、剩余信息保护 | 核查+测试 |
| 5 | 安全管理中心 | 集中管控 | 核查 |
| 6 | 安全建设管理 | 云服务商选择、供应链管理 | 文档审查 |
| 7 | 安全运维管理 | 云计算环境管理 | 核查+访谈 |

# 测评指标适用性原则

云计算安全扩展要求中，不同指标适用于云计算平台或云服务客户业务系统，需要区分适用性。

## 四个区分原则：

| 原则 | 说明 | 适用对象 |
| --- | --- | --- |
| 原则一 | 仅关注云计算平台自身安全防护 | 只适用于云计算平台 |
| 原则二 | 提供需要客户自操作的安全服务 | 同时适用 |
| 原则三 | 分别关注平台和客户各自的安全需求 | 同时适用 |
| 原则四 | 仅关注云服务客户安全需求 | 只适用于客户业务系统 |

## 第三级云平台测评指标适用性（IaaS）示例：

| 要求项 | 适用平台 | 适用客户系统 |
| --- | --- | --- |
| 基础设施位置（中国境内） | | |
| 不同客户虚拟网络隔离 | | |
| 虚拟化网络边界访问控制 | | |
| 虚拟机迁移时策略随其迁移 | | |
| 云服务客户设置虚拟机间访问控制 | | |

# 测评指标适用性原则

云计算安全扩展要求中，不同指标适用于云计算平台或云服务客户业务系统，需要区分适用性。

## 四个区分原则：

| 原则 | 说明 | 适用对象 |
| --- | --- | --- |
| 原则一 | 仅关注云计算平台自身安全防护 | 只适用于云计算平台 |
| 原则二 | 提供需要客户自操作的安全服务 | 同时适用 |
| 原则三 | 分别关注平台和客户各自的安全需求 | 同时适用 |
| 原则四 | 仅关注云服务客户安全需求 | 只适用于客户业务系统 |

## 第三级云平台测评指标适用性（IaaS）示例：

| 要求项 | 适用平台（云服务商） | 适用客户系统（租户） |
| --- | --- | --- |
| 基础设施位置（中国境内） | √ | |
| 不同客户虚拟网络隔离 | √ | |
| 虚拟化网络边界访问控制 | √ | |
| 虚拟机迁移时策略随其迁移 | √ | |
| 云服务客户设置虚拟机间访问控制 | | √ |

# 测评指标解读——安全物理环境（1项）

8.2.1.1 / 9.2.1.1 基础设施位置

| 测评内容 | 要求 | 核查方法 |
| --- | --- | --- |
| a）应保证云计算基础设施位于中国境内 | 云计算平台/系统的硬件设备、数据存储设施必须在中国境内 | 查阅服务协议、查看数据中心位置 |

**等保2.0依据：**

《网络安全法》第37条——“关键信息基础设施的运营者在中华人民共和国境内运营中收集和产生的个人信息和重要数据应当在境内存储。”

## 测评要点：

- ☑ 查看云服务商的数据中心位置说明
- ☑ 核查是否有数据出境的情况
- ☑ 关注：IaaS层的物理设施位置

# 测评指标解读——安全通信网络（3项）

## 8.2.2.1 / 9.2.2.1 网络架构

| 要求项 | 内容 | 适用对象 |
| --- | --- | --- |
| a) | 平台不承载高于自身安全等级的业务应用系统 | 平台 |
| b) | 不同云服务客户虚拟网络之间隔离 | 平台 |
| c) | 提供通信传输、边界防护、入侵防范等安全机制能力 | 平台 |
| d) | 客户可自主设置安全策略（定义访问路径、选择安全组件） | 平台 |
| e) | 开放接口，允许客户接入第三方安全产品 | 平台 |

**四级新增**

f）提供虚拟资源安全标记能力

g）提供通信协议转换/隔离的数据交换方式

h）为第四级业务应用系统划分独立资源池

**要点**

重点关注**b）虚拟网络隔离**和**d）自主设置安全策略**。

# 测评指标解读——安全区域边界

## 8.2.3.1 / 9.2.3.1 访问控制

| 要求项 | 内容 | 适用对象 |
| --- | --- | --- |
| a) | 在虚拟网络边界部署访问控制，设置规则 | 平台+客户 |
| b) | 在不同等级网络区域边界部署访问控制 | 平台+客户 |

## 8.2.3.2 / 9.2.3.2 入侵防范

| | | |
| --- | --- | --- |
| a) | 检测客户发起网络攻击，记录类型/时间/流量 | 平台 |
| b) | 检测对虚拟网络节点的攻击行为 | 平台+客户 |
| c) | 检测虚拟机与宿主机、虚拟机间的异常流量 | 平台+客户 |
| d) | 检测到攻击行为或异常流量时进行告警 | 平台+客户 |

## 8.2.3.3 / 9.2.3.3 安全审计

| | | |
| --- | --- | --- |
| a) | 对远程管理特权命令进行审计（如删/启等） | 平台+客户 |
| b) | 云服务商对客户系统和数据的操作可被审计 | 平台+客户 |

# 测评指标解读——安全计算环境

## 8.2.4.1 / 9.2.4.1 身份鉴别

| 要求项 | 内容 |
| --- | --- |
| （第四级/第三级增强） | 远程管理云计算平台中设备时，管理终端和平台之间应建立双向身份验证机制 |

## 8.2.4.2 / 9.2.4.2 访问控制

| 要求项 | 内容 | 适用对象 |
| --- | --- | --- |
| a) | 虚拟机迁移时，访问控制策略随其迁移 | 平台 |
| b) | 允许云服务客户设置不同虚拟机之间的访问控制策略 | 客户 |

## 8.2.4.3 / 9.2.4.3 入侵防范

| 要求项 | 内容 | 适用对象 |
| --- | --- | --- |
| a) | 检测虚拟机之间的资源隔离失效，并告警 | 平台 |
| b) | 检测非授权新建虚拟机或重新启用虚拟机 | 平台 |
| c) | 检测恶意代码感染及在虚拟机间蔓延 | 平台+客户 |

# 测评指标解读——镜像与数据保护

## 8.2.4.4 / 9.2.4.4 镜像和快照保护

| 要求项 | 内容 |
| --- | --- |
| a) | 针对重要业务系统提供加固的操作系统镜像或安全加固服务 |

## 8.2.4.5 / 9.2.4.5 数据完整性和保密性

a) 云服务客户数据、用户个人信息存储于中国境内，出境需遵循国家规定

b) 只有在客户授权下，云服务商或第三方才具有数据管理权限

## 8.2.4.6 / 9.2.4.6 数据备份恢复

a) 云服务客户应在本地保存其业务数据的备份

b) 提供查询云服务客户数据及备份存储位置的能力

c) 云存储服务保证数据存在若干个可用副本，各副本内容一致

## 8.2.4.7 / 9.2.4.7 剩余信息保护

a) 虚拟机使用的内存和存储空间回收时完全清除

b) 客户删除业务数据时，云存储中所有副本删除

# 云安全配置核查的“检查清单”

## 将等保要求转化为可操作的检查项：

| 检查维度 | 检查内容 | 对应标准 |
| --- | --- | --- |
| 虚拟网络隔离 | 不同租户的VPC是否隔离？ | 8.2.2.1b) |
| 访问控制策略 | 安全组/防火墙策略是否最小权限？ | 8.2.3.1a) |
| 入侵检测 | 是否启用入侵检测/告警？ | 8.2.3.2d) |
| 安全审计 | 特权操作是否记录日志？ | 8.2.3.3a) |
| 镜像安全 | 是否使用加固镜像？ | 8.2.4.4a) |
| 数据备份 | 客户是否有本地备份？ | 8.2.4.6a) |

# 云平台配置检查工具介绍

## 功能概述

云安全中心（阿里云）/ 安全中心（华为云）等平台提供了“云平台配置检查”功能。自动检查云产品的安全配置是否符合最佳实践和合规要求（如等保2.0、CIS基线），识别配置风险并给出修复建议。

## 检查范围示例（以阿里云为例）

| 检查项类别 | 检查内容 |
| --- | --- |
| 身份认证 | 是否启用MFA（多因素认证）、是否存在闲置账户、是否存在弱密码策略 |
| 网络安全 | 安全组规则是否过于宽松、是否开放高危端口（22/3389/3306等） |
| 数据安全 | OSS存储桶是否公共访问、RDS实例是否开启加密、是否启用备份 |
| 审计日志 | 是否启用操作审计、日志留存时间是否满足合规要求 |
| 合规基线 | 是否满足等保2.0、CIS、ISO27001等基线要求 |

01 授权云安全中心访问云资源（创建服务关联角色）

02 执行全量扫描或按策略扫描

03 查看检查结果（风险项列表）

04 处理风险（修复/加白/忽略）

# 云平台配置检查——等保测评视角

素材4：云平台配置检查对照表（快速

| 配置检查结果 | 等保测评影响 | 处理方式 |
| --- | --- | --- |
| 存储桶公共访问 | 不符合数据保密性（8.2.4.5） | 记录为不符合项，建议修改权限 |
| 安全组过于宽松 | 不符合访问控制（8.2.3.1） | 记录为不符合项，建议重新配置 |
| 未启用操作审计 | 不符合安全审计（8.2.3.3） | 记录为不符合项，建议启用审计 |
| 使用默认镜像 | 不符合入侵防范（8.2.4.3） | 记录为部分符合，建议使用加固镜像 |
| 未配置备份 | 不符合数据备份恢复（8.2.4.6） | 记录为不符合项，建议配置备份策略 |

**教学要点：**云平台配置检查是云安全测评的重要技术手段，但不是唯一手段——需要结合登录核查、访谈等综合判断。

# 实验环节｜切换到实践平台，动手做

接下来进入上机实践：教师切换到「信息安全测评实践教学平台 → 7.1 云计算」单元，在 CloudLab 模拟环境里演示核查流程并布置任务——本页只做预告，具体步骤在平台上跟着走。

🩹实验二｜云安全配置核查（课堂 45 分钟）

· 做什么：7 项指标逐项取证 → 四档判定 → 写问题描述与整改建议 → 导出记录表
· 看哪里：平台「等保核查任务」页，每项都有「前往取证页」按钮跳到现场
· 再进一步：从 5 处配置风险里至少找出 3 处真实风险，并说出对应的等保条款
· 交什么：《云计算安全测评记录表》+ 风险识别得分截图，提交学习通

📋判定口径：符合 / 部分符合 / 不符合 / 不适用

· 写判定要带依据：哪条配置、什么值、对哪个条款，不写“不满足”三个字了事

⏱ 课堂节奏：教师演示 15 分钟 → 学生动手 30 分钟 → 当堂导出提交

🌐入口：cloudlab-experiment.html →「等保核查任务」｜素材 2-1 ~ 2-5 与判定标准都在平台单元里。

# 思政融入——云上安全，“每一个配置都是责任”



## 合规

- 等保2.0明确要求“云计算基础设施位于中国境内”
- 数据安全是国家安全的组成部分



## 责任

- 云平台配置错误——哪怕是“一个复选框”，也可能导致大规模数据泄露
- 测评师的每一次核查，都是在守护用户的“数据资产”



## 严谨

- 云安全配置核查需要“逐项对照标准”
- “差不多”在安全面前，就是“差很多”

**云上的每一行配置，都关乎数据安全；测评师的每一份记录，都关乎合规底线。**

# 知识点回顾（5分钟）

## 云安全配置核查

### 一、等保2.0云计算扩展要求

- 安全物理环境（基础设施位置）
- 安全通信网络（网络架构、隔离）
- 安全区域边界（访问控制、入侵防范、审计）

### 二、测评指标适用性

- 平台责任 vs 客户责任
- 四个区分原则

### 三、配置核查实操

- VPC隔离、安全组策略
- 审计日志、加固镜像
- 备份策略、剩余信息保护

### 四、云平台配置检查工具

- 自动扫描配置风险
- 与等保测评的关联

# 课后作业

| | |
|---|---|
| 必做 | 完成《云计算安全测评记录表》（基于 CloudLab 实验平台核查结果，可从页面直接导出），提交至学习通平台 |
| 必做 | 完成活动7.1.2在线测试（选择题+判断题，共15题） |
| 选做 | 登录阿里云/华为云免费试用，体验“云平台配置检查”功能（可截图） |
| 预习 | 预习7.2.1“移动互联架构认知”相关内容 |

# 下节课预告

## 预告内容

- 移动互联系统架构特点
- 移动安全扩展要求概述
- 移动终端、移动应用、无线网络

## 课前准备

1. 了解移动互联安全的基本概念
2. **思考：**手机里的APP安全吗？



# 常见问题与答疑

## Q1：云平台配置检查工具能替代人工核查吗？

不能完全替代。工具可以发现配置类风险（如权限错误、端口开放），但无法判断业务逻辑合理性（如“这个端口是否真的需要开放？”）。人工核查是必要的补充。

## Q2：如果一个云平台承载了多个等级的业务系统，怎么测评？

原则：云平台的安全保护等级应不低于其承载的最高等级业务系统。即如果云平台承载了三级业务系统，云平台本身至少应按三级要求测评。

## Q3：混合云场景怎么划分责任？

混合云中，公有云部分适用云计算扩展要求，私有云部分适用安全通用要求。责任划分需根据具体服务模式确定。

# 课堂小结

## 1 三个核心知识点

①云计算安全扩展要求包含7个安全类，需区分平台责任与客户责任；

②安全区域边界（访问控制/入侵防范/审计）和安全计算环境（身份鉴别/镜像/数据保护）是核查重点；

③云平台配置检查工具可辅助识别配置风险

## 2 两个关键技能

①能依据等保要求对云平台进行安全配置核查；

②能规范填写《云计算安全测评记录表》

## 3 一个职业准则

云安全测评需要“**逐项对照、逐条记录**”，严谨是对数据安全的最大尊重

# 感谢观看

